

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- By the end of this guide, you will be able to recall all six Domain 1 sub-domains and their highest-yield exam topics with precision.
- By the end of this guide, you will be able to apply the shared responsibility model to scenario-based questions and correctly assign security ownership in IaaS, PaaS, and SaaS contexts.
- By the end of this guide, you will be able to distinguish between key certification and audit types — including SOC 1 vs. SOC 2, ISO 27001 vs. 27017 vs. 27018, and FedRAMP authorization tiers — and identify the correct reference for each evaluation context.
- By the end of this guide, you will be able to differentiate data sanitization methods (crypto-shredding, degaussing, overwriting, physical destruction) and select the appropriate method for cloud environments.
- By the end of this guide, you will be able to identify common Domain 1 exam traps — including multi-tenancy vs. multi-cloud confusion and SOC 1 vs. SOC 2 conflation — and apply strategies to avoid them.
- By the end of this guide, you will be able to articulate the three foundational principles of Domain 1 that underpin the remaining CCSP domains.

Introduction

Domain 1 of the CCSP — Cloud Concepts, Architecture and Design — accounts for 17 percent of the August 2026 exam, translating to approximately 17 to 26 questions in a typical Computerized Adaptive Testing session. This is the foundational domain: the NIST cloud computing definitions, shared responsibility model, secure data lifecycle, and CSP evaluation frameworks introduced here appear as embedded assumptions throughout every subsequent domain. Mastery of Domain 1 is not merely about answering a fixed block of questions correctly — it establishes the conceptual vocabulary and risk-management lens that the entire exam tests.

The exam tips lecture synthesizes the six sub-domains of Domain 1 into the highest-yield concepts and most actionable guidance for test day. Sub-domain 1.1 grounds the exam in the NIST SP 800-145 definition — five essential characteristics, three service models, four deployment models. Sub-domains 1.2 and 1.3 extend into roles and security concepts including key management, IAM federation, and the cloud secure data lifecycle. Sub-domain 1.4 addresses design principles including BC/DR planning through RTO and RPO. Sub-domain 1.5 covers CSP evaluation through certifications and audit reports. The new sub-domain 1.6 adds AI and ML security comprehension as an explicit exam component for the August 2026 update.

This guide consolidates those threads into an exam-ready reference. It is structured to mirror how Domain 1 content is actually tested: scenario-based application of the shared responsibility model, precise distinctions between similar-sounding certifications, and recognition of the risk-management mindset ISC2 consistently

applies across all answer choices. CAT exam strategy — including performance momentum, question confidence, and disambiguation heuristics — is addressed in context.

Core Concepts Explained

NIST SP 800-145: Five Essential Characteristics

Definition: NIST SP 800-145 defines cloud computing through five essential characteristics: on-demand self-service, broad network access, resource pooling, rapid elasticity, and measured service. These characteristics distinguish genuine cloud computing from hosted or managed services and appear on the CCSP exam in multiple question formats.

Business relevance: The five characteristics are the contractual and architectural baseline for evaluating any cloud offering. A service that lacks rapid elasticity, for instance, may be traditional managed hosting misbranded as cloud — a meaningful distinction for risk assessment, SLA negotiation, and regulatory compliance when the applicable framework references NIST cloud definitions.

Cloud Security Practitioner relevance: For a Cloud Security Practitioner, these characteristics are the lens through which architectural decisions are validated. Measured service enables the usage-based billing that drives cost-allocation security controls; resource pooling introduces the multi-tenancy considerations that require data isolation verification; on-demand self-service is the underlying assumption behind cloud IAM policies that prevent unauthorized provisioning.

Real-world example: A mid-sized financial services firm migrated from a traditional data center to a major public cloud provider. During a regulatory audit, the examiner asked the firm's Cloud Security Architect to demonstrate that the environment qualified as cloud computing under NIST SP 800-145. The architect prepared a mapping document: she showed that engineers could provision compute instances without contacting the provider (on-demand self-service), that workloads were accessible via standard HTTPS APIs from both office and remote locations (broad network access), that the underlying hardware served multiple tenant organizations simultaneously (resource pooling), that auto-scaling groups adjusted instance counts in response to traffic spikes within minutes (rapid elasticity), and that CloudWatch delivered per-resource billing metrics to the firm's FinOps team in real time (measured service). The audit passed. When a new product team later proposed a 'cloud solution' with a fixed-capacity reserved cluster and no usage metering, the architect correctly identified it as a colocation arrangement rather than a NIST-compliant cloud deployment — a distinction with direct implications for the firm's cloud-specific cyber insurance policy.

Risks or limitations: Misidentifying a non-cloud service as cloud computing leads to misapplied shared responsibility assumptions, incorrect contractual protections, and regulatory non-compliance where specific cloud definitions govern scope. The best practice is to formally evaluate every new service relationship against the NIST SP 800-145 criteria before designating it as cloud in risk documentation.

Shared Responsibility Model in Service Models

Definition: The shared responsibility model defines which security controls are owned by the cloud service provider and which by the customer, depending on the service model. In IaaS, customers manage OS, runtime, middleware, applications, and data. In PaaS, customers manage applications and data; the CSP manages infrastructure and runtime. In SaaS, customers manage data and sometimes user access configuration; the CSP manages nearly everything else.

Business relevance: Shared responsibility directly determines accountability during security incidents. When a database engine vulnerability is exploited on a PaaS platform, the CSP is responsible for patching the managed

engine — but the customer bears responsibility if the application code did not validate inputs. Misunderstanding the boundary creates governance gaps that regulators — and litigants — identify quickly.

Cloud Security Practitioner relevance: A Cloud Security Practitioner must be able to produce a shared responsibility matrix for every service deployed in the organization's cloud portfolio. This matrix drives security control assignment, audit evidence responsibility, and contractual remediation rights. It is a living document: as services evolve, their classification can shift.

Real-world example: A healthcare organization running an electronic health records application experienced a data breach. The breach investigation revealed two distinct failures: first, the managed relational database service (PaaS) had a known vulnerability in its query engine that the CSP had not yet patched; second, the application team had stored unencrypted PHI in a world-readable storage bucket (customer-configured). The incident response team applied the shared responsibility model formally. The unpatched query engine: the CSP owned patching responsibility for the managed engine in PaaS — this was a CSP failure documented in the breach notification. The world-readable bucket: the customer configured access permissions — this was a customer failure and the source of regulatory exposure under HIPAA. The organization's CISO used this incident to mandate shared responsibility matrix reviews as part of every architecture review board process, with a specific sign-off requirement before any new PaaS or SaaS service was approved for PHI handling.

Risks or limitations: The most common failure mode is assuming that the CSP secures everything in a managed service, leading customers to skip application-level security controls, data classification, and IAM hardening. The prevention is explicit, documented shared responsibility mapping before deployment, not after an incident.

Data Sanitization in Cloud Environments: Crypto-Shredding

Definition: Data sanitization is the process of making data permanently inaccessible at the end of its lifecycle or when it must be removed from a system. In cloud environments, the primary methods are crypto-shredding (destroying encryption keys, rendering encrypted data unreadable), overwriting (for spinning disk), degaussing (for magnetic media), and physical destruction (most definitive but requires physical access). Crypto-shredding is typically the most practical and verifiable option in cloud contexts.

Business relevance: Regulated industries — financial services, healthcare, government — require evidence of data destruction at end-of-life. In cloud environments where the customer does not control or have access to physical hardware, producing that evidence through traditional means (a certificate of destruction from a drive-shredding vendor) is impossible. Crypto-shredding provides a cryptographically verifiable substitute: the audit trail shows the keys were destroyed, and without the keys the data is computationally irretrievable.

Cloud Security Practitioner relevance: Cloud Security Practitioners must design data lifecycle policies that specify sanitization method by media type and cloud service model. For encrypted data stored in cloud object storage or managed databases, the policy should designate crypto-shredding as the standard method and require key custody logs from the key management system as audit evidence. Physical destruction clauses in cloud contracts are typically aspirational — crypto-shredding is the operational reality.

Real-world example: A global retail company terminated its contract with a cloud storage provider after migrating to a competing platform. The data governance team faced a regulatory requirement under GDPR Article 17 (right to erasure) to demonstrate permanent deletion of customer PII from the previous provider's storage. The organization had adopted a data-at-rest encryption strategy using customer-managed keys stored in a dedicated Hardware Security Module. The Cloud Security Architect directed the key custodian to formally destroy the encryption keys via the HSM's certified erasure process, generating a key destruction certificate logged with the HSM's audit trail. The architect then documented the crypto-shredding in the data processing records, cross-referencing the HSM audit log as evidence of irretrievability. When the previous provider's data

protection officer confirmed that residual encrypted data remained on retired media, the company was able to demonstrate to the supervisory authority that the data was cryptographically inaccessible — satisfying GDPR's 'effectively erasure' standard without requiring physical access to the provider's hardware.

Risks or limitations: Crypto-shredding only works if data was encrypted before storage — retroactive encryption of existing unencrypted data requires a full re-encryption pass. The best practice is to mandate encryption at rest for all cloud-stored data from initial deployment, so crypto-shredding is always an available option at end-of-life.

CSP Evaluation: Certifications and Audit Reports

Definition: CSP evaluation relies on third-party certifications and audit reports because cloud customers cannot directly inspect provider infrastructure. Key frameworks include: SOC 2 Type II (operational effectiveness over time for security, availability, processing integrity, confidentiality, privacy); ISO 27001 (ISMS certification); ISO 27017 (cloud-specific security controls); ISO 27018 (cloud PII/privacy controls); FedRAMP (US government cloud authorization at Low, Moderate, High); FIPS 140-2/140-3 (cryptographic module validation); Common Criteria ISO/IEC 15408 (IT product evaluation); and CSA STAR (cloud-specific using the Cloud Controls Matrix).

Business relevance: Third-party assurance replaces direct audit rights that cloud customers cannot exercise. A SOC 2 Type II report covering a 12-month period tells procurement, legal, and security teams that an independent auditor observed the controls actually operating — not merely designed — over that period. This is the closest approximation to internal audit access that cloud procurement typically achieves.

Cloud Security Practitioner relevance: Cloud Security Practitioners evaluate CSP documentation packages as part of vendor due diligence. A complete package for a regulated workload should include a current SOC 2 Type II report, ISO 27001 certificate with scope statement, ISO 27017/27018 where applicable, FedRAMP ATO letter for US government work, and FIPS 140-2/140-3 validation for any cryptographic services in scope. Missing or expired reports are a procurement risk signal requiring compensating controls or contract remediation rights.

Real-world example: A federal contractor preparing to deploy a sensitive but unclassified workload on a commercial cloud platform initiated a CSP evaluation. The security team's evaluation checklist required: a FedRAMP Moderate authorization-to-operate letter with an assessment date within 12 months (to ensure recency), a SOC 2 Type II report covering security and availability (Type I was explicitly rejected as insufficient because it only demonstrated point-in-time design, not operational effectiveness), and FIPS 140-3 Level 2 validation for the provider's key management service. The incumbent provider submitted a SOC 1 report and a SOC 2 Type I report. The security team rejected both — SOC 1 is scoped to financial reporting controls, not security, and Type I does not demonstrate operating effectiveness over time. The competitor provider submitted the full package. The evaluation resulted in contract award to the competitor, with the SOC 1/Type I conflation documented as a risk finding in the procurement record as a cautionary note for future evaluations.

Risks or limitations: Accepting a SOC 1 report or a SOC 2 Type I when a Type II is required provides false assurance. The correct practice is to specify required report types in the vendor questionnaire and RFP and reject substitutes without compensating controls review.

AI and ML Security Concepts in Cloud (Sub-Domain 1.6)

Definition: Sub-domain 1.6, new in the August 2026 CCSP exam, covers AI and ML from a cloud security perspective. Key exam topics include: ML-powered threat detection (UEBA, anomaly detection at cloud scale), data source validation to prevent model poisoning, SOAR platform automation using cloud APIs, adversarial ML attack types (evasion attacks, model poisoning, model extraction), ethical AI considerations (bias, explainability, accountability), and the primary regulatory/framework references: the EU AI Act and the NIST AI Risk Management Framework (AI RMF).

Business relevance: Cloud-scale AI/ML introduces both capability and risk. On the capability side, behavioral analytics at the scale of cloud telemetry — billions of API calls and authentication events per day — enables threat detection that rule-based systems cannot match. On the risk side, ML models trained on cloud data are themselves assets that must be protected: a poisoned training dataset can cause systematic detection failures, and an extracted model exposes proprietary detection logic to adversaries.

Cloud Security Practitioner relevance: Cloud Security Practitioners must understand AI/ML security at two levels: evaluating AI-powered security tools for trustworthiness (is the vendor's model validated, is training data auditable, what is the false-positive rate?) and defending against AI-specific attacks on cloud ML workloads (is training data access controlled, is model output monitored for adversarial drift, are model endpoints protected by API gateway policies?).

Real-world example: A large financial services firm deployed a cloud-native UEBA platform to detect insider threats across its multi-cloud environment. Six months after deployment, the security operations team noticed that the platform's anomaly detection scores had drifted: previously flagged behaviors (unusual data exfiltration patterns outside business hours) were now being scored as benign. Investigation revealed that a disgruntled administrator had gradually introduced falsified activity records into the telemetry feed used as training data for the behavioral baseline — a data poisoning attack conducted over three months. The incident prompted a remediation program aligned with NIST AI RMF Govern and Measure functions: the firm implemented cryptographic integrity controls on telemetry ingestion pipelines, established a quarterly model validation process with a held-out clean dataset, and designated a model risk owner in the enterprise risk committee. The EU AI Act's requirements for high-risk AI system documentation were cited in the remediation report as the external governance standard the firm was aligning to.

Risks or limitations: AI/ML security is often treated as purely a data science problem. The cloud security practitioner's role is to apply standard security disciplines — access control, integrity validation, monitoring, incident response — to AI systems as assets, not just tools. Data poisoning prevention requires treating training data pipelines with the same security controls applied to production systems.

Practical Applications

The following scenarios illustrate how Domain 1 exam-tip concepts apply to real practitioner decisions — from CAT exam strategy to incident response to vendor evaluation.

Applying the Shared Responsibility Model During an Incident

A Cloud Security Practitioner receives an alert at 2:00 AM: customer data has appeared in a public paste site. The incident response process begins with a service model classification step — the breached service is a managed container platform (PaaS). The practitioner works through the shared responsibility matrix: the container orchestrator and underlying OS are CSP-managed, but the application code, container images, and IAM policies are customer-managed. The forensic timeline shows that the data exfiltration originated from a container running with an over-privileged service account that had read access to the full data store. This is a customer responsibility failure — over-permissioned service account, a violation of least-privilege IAM policy. The practitioner documents this finding in the incident report and the post-incident review specifies a corrective action: service accounts will be scoped to minimum required permissions as part of the pre-deployment security checklist. When a parallel investigation reveals an unpatched vulnerability in the managed container runtime, that finding is escalated to the CSP as a provider-responsibility deficiency, with contractual remediation rights invoked per the customer agreement. The two findings are tracked in separate remediation workstreams — one internal, one external — reflecting the shared responsibility boundary accurately.

Selecting a Deployment Model for a Regulated Workload

A healthcare network's board has approved a new telehealth platform that will process PHI for patients across three US states. The Cloud Security Practitioner is asked to recommend a deployment model. The requirements are: HIPAA compliance, no co-mingling of PHI with non-healthcare tenant data, ability to use existing on-premises identity infrastructure for physician authentication, and a cost profile acceptable for a regional healthcare network rather than a large academic medical center. The practitioner evaluates each deployment model against these requirements. Public cloud — shared multi-tenant infrastructure — fails the no-co-mingling requirement unless a dedicated tenancy option is available at acceptable cost. Private cloud (on-premises) satisfies isolation and identity integration but fails the cost requirement given the scale of the telehealth workload. Community cloud, specifically a healthcare-sector cloud operated for covered entities under a BAA framework, satisfies all requirements: it serves multiple healthcare organizations with shared HIPAA compliance obligations, uses logically isolated tenant environments, and supports federation with existing on-premises identity providers. The practitioner recommends community cloud and documents the deployment model selection with a requirements traceability matrix — a deliverable that will serve double duty as evidence for the HIPAA security rule administrative safeguards audit.

Developing a CAT Exam Strategy for Domain 1 Questions

A CCSP candidate sits down for the exam knowing Domain 1 carries 17 percent of the weight and often appears early in the CAT session because foundational domain performance shapes the adaptive algorithm's difficulty calibration. The candidate encounters a question describing a scenario where a retail company's point-of-sale application, hosted on a CSP-managed database service, experienced a SQL injection attack. The question asks who is responsible for the vulnerability. The candidate applies a structured disambiguation approach: first, identify the service model (managed database = PaaS); second, locate the vulnerability in the shared responsibility matrix (SQL injection is an application-layer vulnerability — the application code validates inputs, and that code is customer-managed even in PaaS); third, confirm the answer aligns with the risk-management, security-first lens ISC2 consistently applies. The answer is the customer — they own application-layer input validation. The candidate does not select the CSP answer despite the fact that the database is managed, because the managed service boundary stops at the database engine, not the application queries sent to it. When the next question presents two plausible answers and the candidate is uncertain, they apply the ISC2 heuristic: the answer that reflects proactive, risk-based, defense-in-depth security thinking is preferred over the reactive or cost-minimizing option. This approach, applied consistently, is more reliable than topic-by-topic memorization alone.

Best Practices

- **Map shared responsibility explicitly before deployment, not after an incident.** For every cloud service in scope, produce a written shared responsibility matrix that names the specific security control, identifies whether the customer or CSP owns it, and cites the contractual or documentation source. This matrix should be signed off by the application owner and security team before the service goes live. During the CCSP exam, use this mental model to answer scenario questions: identify the service model first, then locate the control in the matrix before selecting an answer.
- **Require SOC 2 Type II reports, not Type I, for cloud vendor due diligence.** Specify in vendor questionnaires and contracts that SOC 2 Type II coverage is required for the services in scope, with no exceptions for Type I reports or substitution of SOC 1 reports. Type II demonstrates that controls operated effectively over a defined period — typically six to twelve months — not merely that they were designed. Verify that the audit

period is current (within 12 months) and that the scope covers the specific services and data centers your organization uses.

- **Implement crypto-shredding as the default data destruction method for cloud-stored encrypted data.** Design data-at-rest encryption policies so that customer-managed keys are used for all regulated data stored in cloud environments, and key custody is maintained in a dedicated HSM or cloud KMS with full audit logging. At end-of-life or contract termination, the key destruction event — logged by the KMS — becomes the primary evidence of data disposal. Maintain a data destruction register that cross-references each destruction event with the KMS audit log entry, the data asset inventory, and the relevant regulatory requirement.
- **Know the RTO and RPO for each critical system and verify they are achievable in your current architecture.** Business Impact Analysis defines RTO and RPO requirements; architecture validation confirms whether the current backup, replication, and failover design can actually meet them. Conduct tabletop exercises and partial failover tests at least annually to verify that cloud-based BC/DR capabilities — multi-region replication, geo-redundant storage, managed failover — perform as designed under real failure conditions, not just theoretical SLAs.
- **Apply the NIST AI RMF Govern and Measure functions to AI-powered security tools.** For any ML-based security platform (UEBA, anomaly detection, SOAR) in your cloud environment, designate a model risk owner, document the training data sources and update cadence, establish cryptographic integrity controls on telemetry ingestion pipelines, and schedule quarterly model validation against a held-out clean dataset. Treat AI models as regulated assets with the same access control, integrity, and audit logging requirements applied to production data.

Common Mistakes and Misconceptions

Misconception: Confusing SOC 1 with SOC 2 and accepting a SOC 1 report as evidence of cloud security controls.

Correct approach: SOC 1 addresses controls relevant to financial reporting, not security. The correct practice is to specify SOC 2 Type II in vendor questionnaires and reject substitutes. During the CCSP exam, when a question asks which report evaluates a cloud provider's security controls, the answer is SOC 2 — not SOC 1.

Misconception: Confusing multi-tenancy with multi-cloud and treating them as equivalent terms.

Correct approach: Multi-tenancy means multiple customers share physical infrastructure with logical isolation — this is the default architecture of public cloud and a feature, not a flaw. Multi-cloud means using multiple public cloud providers for different workloads to reduce vendor lock-in or improve resilience. When an exam scenario describes shared physical infrastructure, the correct term is multi-tenancy; when it describes using AWS and Azure simultaneously, the correct term is multi-cloud.

Misconception: Assuming the CSP is responsible for all security in a managed (PaaS/SaaS) service.

Correct approach: Even in fully managed services, the customer retains responsibility for application-layer security, data classification, IAM configuration, and often encryption key management. The best practice is explicit shared responsibility mapping for each service, verified against the CSP's published responsibility documentation, before deployment.

Misconception: Planning for crypto-shredding at end-of-life but never encrypting the data at rest during active use.

Correct approach: Crypto-shredding only renders data inaccessible if the data was encrypted before storage. The correct practice is to mandate encryption at rest for all regulated data from initial deployment using

customer-managed keys, ensuring that crypto-shredding is always an available and auditable disposal mechanism.

checklist: Domain 1 Pre-Exam Review Checklist

Use this checklist in the 24 to 48 hours before your CCSP exam to verify that your Domain 1 knowledge gaps are closed. Each item maps to a high-yield exam topic identified in the exam tips lecture.

- ☐ Can I recite the five NIST SP 800-145 essential characteristics and give a one-sentence definition of each without notes?
- ☐ Can I describe the shared responsibility boundary in IaaS, PaaS, and SaaS, and assign a scenario-based vulnerability to the correct responsible party?
- ☐ Can I name all four deployment models (public, private, community, hybrid) plus multi-cloud, and identify the security trade-off associated with each?
- ☐ Can I state the difference between SOC 1, SOC 2 Type I, and SOC 2 Type II — and identify which is required for cloud security evaluation?
- ☐ Can I name the six phases of the cloud secure data lifecycle (Create, Store, Use, Share, Archive, Destroy) and identify one primary security control for each?
- ☐ Can I define RTO and RPO, and explain why both must be validated through testing rather than inferred from SLAs?
- ☐ Can I explain why crypto-shredding is the preferred data destruction method in cloud environments and what prerequisite (encryption at rest) it requires?
- ☐ Can I distinguish ISO 27001, 27017, and 27018 by scope — ISMS, cloud controls, and cloud PII respectively?
- ☐ Can I identify the three FedRAMP authorization tiers (Low, Moderate, High) and explain what a 3PAO does?
- ☐ Can I name at least two adversarial ML attack types (evasion, model poisoning, model extraction) and explain the NIST AI RMF as the primary US governance framework for AI risk?
- ☐ Do I know the CAT exam heuristic: when two answers seem valid, choose the one most consistent with proactive, risk-based, defense-in-depth security thinking?

How to use this: *If you cannot answer any item from memory without hesitation, review the corresponding sub-domain lecture before sitting the exam. Domain 1 concepts appear embedded in questions across all six CCSP domains — gaps here compound throughout the exam.*

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. A cloud customer's managed relational database service (PaaS) suffers a data breach traced to an unpatched vulnerability in the database engine itself. Who bears primary responsibility for remediation of this vulnerability?

- A) A. The customer, because they selected the database service and accepted its risk profile.
- B) B. The CSP, because in PaaS the provider manages the database engine and its patching.

- C) C. Both equally, because the shared responsibility model assigns patching to the party that configured the service.
- D) D. The customer's third-party auditor, because they should have identified the vulnerability in the most recent SOC 2 assessment.

Answer: B. The CSP, because in PaaS the provider manages the database engine and its patching.

Q2. A regulatory auditor requests evidence that a cloud service provider's security controls have been operating effectively over the past 12 months — not merely that they were designed to operate. Which report type satisfies this requirement?

- A) A. SOC 1 Type II, which covers operational effectiveness of financial reporting controls.
- B) B. SOC 2 Type I, which covers security control design at a specific point in time.
- C) C. SOC 2 Type II, which covers the operational effectiveness of security controls over a defined period.
- D) D. ISO 27001 certificate, which certifies the ISMS design and scope.

Answer: C. SOC 2 Type II, which covers the operational effectiveness of security controls over a defined period.

Q3. A cloud organization needs to demonstrate permanent disposal of customer PII stored on a CSP's infrastructure at contract termination. The organization does not have physical access to the storage media. Which sanitization method is most appropriate?

- A) A. Degaussing, which destroys magnetic fields on spinning disk and tape media.
- B) B. Overwriting, which writes patterns of zeros and ones over existing data on spinning disk.
- C) C. Crypto-shredding, which destroys the encryption keys rendering encrypted data computationally inaccessible.
- D) D. Physical destruction, which shreds or melts the storage media to ensure data is unrecoverable.

Answer: C. Crypto-shredding, which destroys the encryption keys rendering encrypted data computationally inaccessible.

Q4. A CCSP candidate encounters this exam question: 'An organization uses a cloud platform that runs workloads for multiple customers simultaneously on shared physical servers, with logical isolation between tenants. The organization also uses a second cloud provider for backup and archival. Which terms correctly describe these two arrangements?' What is the correct answer?

- A) A. Multi-cloud for the first arrangement; multi-tenancy for the second.
- B) B. Multi-tenancy for the first arrangement; multi-cloud for the second.
- C) C. Hybrid cloud for the first arrangement; community cloud for the second.
- D) D. Both arrangements are examples of multi-tenancy because multiple parties share resources in each case.

Answer: B. Multi-tenancy for the first arrangement; multi-cloud for the second.

Q5. A security operations team discovers that the anomaly detection scores from their cloud-native behavioral analytics platform have drifted over three months, causing previously flagged exfiltration patterns to be scored as benign. Investigation reveals that falsified telemetry records were introduced into the platform's training data pipeline. Which AI/ML attack type does this represent, and which NIST framework function most directly addresses prevention?

- A) A. Model extraction attack; NIST AI RMF Respond function.
- B) B. Evasion attack; NIST AI RMF Govern function.
- C) C. Data poisoning (model poisoning) attack; NIST AI RMF Measure function.

D) D. Adversarial prompt injection; NIST AI RMF Map function.

Answer: C. Data poisoning (model poisoning) attack; NIST AI RMF Measure function.

Reflection Questions

1. Which of the six Domain 1 sub-domains felt least certain to me after this review, and what specific action will I take to close that gap before the exam?
2. Can I explain the shared responsibility boundary in IaaS, PaaS, and SaaS to a non-technical colleague without referring to notes? If not, what would help me internalize it more durably?
3. Have I encountered any real-world situations in my professional role where the shared responsibility boundary was ambiguous or disputed? How would I handle that situation with the knowledge from Domain 1?
4. How does the CSP evaluation framework — certifications, SOC reports, contractual rights — apply to vendor relationships in my current organization? Are there gaps between what we require and what Domain 1 best practice recommends?
5. The CAT exam heuristic (choose the risk-based, defense-in-depth answer) reflects ISC2's underlying security philosophy. Can I identify at least two practice questions where this heuristic led me to the correct answer when topic knowledge alone was insufficient?
6. Domain 2 builds directly on Domain 1 — the data lifecycle, encryption, and shared responsibility principles all carry forward. What are the two or three Domain 1 concepts I should keep top-of-mind as I begin Domain 2 preparation?

Key Takeaways

- Domain 1 accounts for 17 percent of the CCSP exam and provides the conceptual foundation for all five remaining domains — investment in Domain 1 mastery pays compound returns throughout the exam.
- The NIST SP 800-145 five essential characteristics (on-demand self-service, broad network access, resource pooling, rapid elasticity, measured service) are the definitional baseline for cloud computing and appear across multiple question formats.
- The shared responsibility model is the single most frequently applied framework in CCSP scenario questions — correctly identifying the service model (IaaS/PaaS/SaaS) and locating the control in the responsibility matrix is the reliable path to the correct answer.
- SOC 2 Type II is the gold standard for cloud security assurance — it demonstrates that controls operated effectively over time, distinguishing it from Type I (point-in-time design) and SOC 1 (financial reporting scope).
- Crypto-shredding is the primary data destruction method available in cloud environments; it requires encryption at rest with customer-managed keys as a prerequisite.
- Multi-tenancy (shared infrastructure, logical isolation) and multi-cloud (multiple providers) are distinct concepts that represent a documented exam trap — know the difference cold.
- Sub-domain 1.6 on AI/ML is new in August 2026 and includes adversarial ML attack types (evasion, model poisoning, model extraction), UEBA-based detection, and the NIST AI RMF and EU AI Act as the primary governance references.
- ISC2's consistent exam heuristic: when two answers are plausible, the correct answer most clearly reflects proactive, risk-based, defense-in-depth security thinking and shared responsibility awareness.

Recommended Next Actions

Put this lecture to work within the next seven days:

7. Complete the Domain 1 Pre-Exam Review Checklist (provided in this guide) and for any item you cannot answer from memory without hesitation, return to the corresponding lecture before sitting the exam.
8. Draft a one-page shared responsibility matrix for a cloud service you use in your current role — categorize five specific security controls as either customer-owned or CSP-owned, and verify your categorization against the provider's published shared responsibility documentation.
9. Request the most recent SOC 2 Type II report from one cloud vendor in your organization's portfolio, verify that the audit period is current (within 12 months), and confirm that the scope statement covers the specific services and data centers your organization uses.
10. Review your organization's current data destruction policy for cloud-stored data and confirm that: (a) regulated data is encrypted at rest with customer-managed keys, and (b) the policy designates crypto-shredding with KMS audit log evidence as the standard disposal method — escalate any gaps to your data governance team.